

PROOF OF CONCEPT

CSPM PoC Guide

*AccuKnox CNAPP — AWS Multi-Account /
Zero Trust from Code to Cloud*

Certified & Accredited by



As Featured In



Available On



Table of Contents

1	POC Prerequisites & Readiness Checklist
2	Cloud Account Onboarding Diagrams (CSPM)
3	CSPM PoC Use Cases
4	Integrations & Channel Alert Configuration
6	POC Timelines Execution Plan
7	CSPM Report, Collaborative Triaging & Executive Summary

Onboarding Workflow — Cloud Account to First Scan



01

Deployment
Model

02

Cloud Provider
Selection

03

IAM Role
Provisioning

04

Asset Tagging &
Scope

05

Integration
Setup

06

Automated
Cloud Security
Scan



Select Accounts

Choose your cloud
& accounts.



Grant Permissions

Set up access for
reading & testing.



Label Resources

Tag your assets by
team & type.



Connect Apps

Link tools like Slack
or Jira.



Automated Cloud Security Scan

Continuously monitor &
scan for vulnerabilities

CSPM POC Steps - Onboard, Monitor, Report



AWS Accounts

Org Unit or Standalone
EKS · EC2 · RDS · Bedrock

Cloud Telemetry

CloudTrail · Config
VPC Flow Logs · GuardDuty

AccuKnox Control Plane

1500+ Policies
CSPM · CDR · AI Copilot

Response & Reporting

Jira · Slack · ServiceNow
Auto-Remediation ·
Reports

100% Agentless, Event-Driven — no kernel modules, no intrusive agents

Data Ingestion

Method

100% API-based read — no data stored
outside tenant boundary

Sources

CloudTrail, AWS Config, VPC Flow Logs,
GuardDuty findings, Bedrock audit logs

Asset Types

50+ types: Compute, Storage, Network,
IAM, Databases, AI/ML, Serverless

Analysis Engine

Policy Library

1500+ built-in controls mapped to CIS,
NIST, SOC2, HIPAA, PCI-DSS

Attack Path

Toxic Combination correlation — chains
misconfigs into exploitable paths

AI Copilot

AskADA GenAI: asset-specific CLI /
Terraform fix snippets on demand

Response Layer

Ticketing

Dynamic Jira / ServiceNow templates
auto-populated with asset ID +
severity

Alerting

Real-time Slack, Teams, PagerDuty,
Email — severity-filtered routing

Auto-Remediation (CDR)

Webhook → Lambda / serverless — S3,
EC2, IAM rollback in < 2 min

POC Prerequisites & Readiness Checklist



A AWS Account Scope

Deployment Models	SaaS - simplest and fastest, On-Prem if you want airgapped and self-managed cloud scanning
Account Type	Either an AWS Organization Unit (OU) or a standalone AWS Account — both supported
Cloud Resources	Account must contain: EKS Cluster, EC2 Instances, RDS / Database, AI assets (Amazon Bedrock)
IAM Permissions	Read-only role for discovery phase. Contributor/write role required for CDR auto-remediation
Onboarding Reference	Prereq & onboarding steps for cloud account connection → STANDALONE ORGANIZATION

B Compliance, AI & CDR (You Pick)

Compliance Frameworks Supported

CIS v2.0, NIST 800-53, SOC2 Type II, HIPAA

CDR Permissions (AWS)

s3:PutBucketPublicAccessBlock
ec2:TerminateInstances | cloudtrail:StartLogging

AI / LLM Footprint (Optional)

Confirm active Amazon Bedrock models
OpenAI / other LLM connectors in-scope

C Integrations (Optional)

Ticketing

Jira Project (reference Jira integration doc)
ServiceNow optional alternative

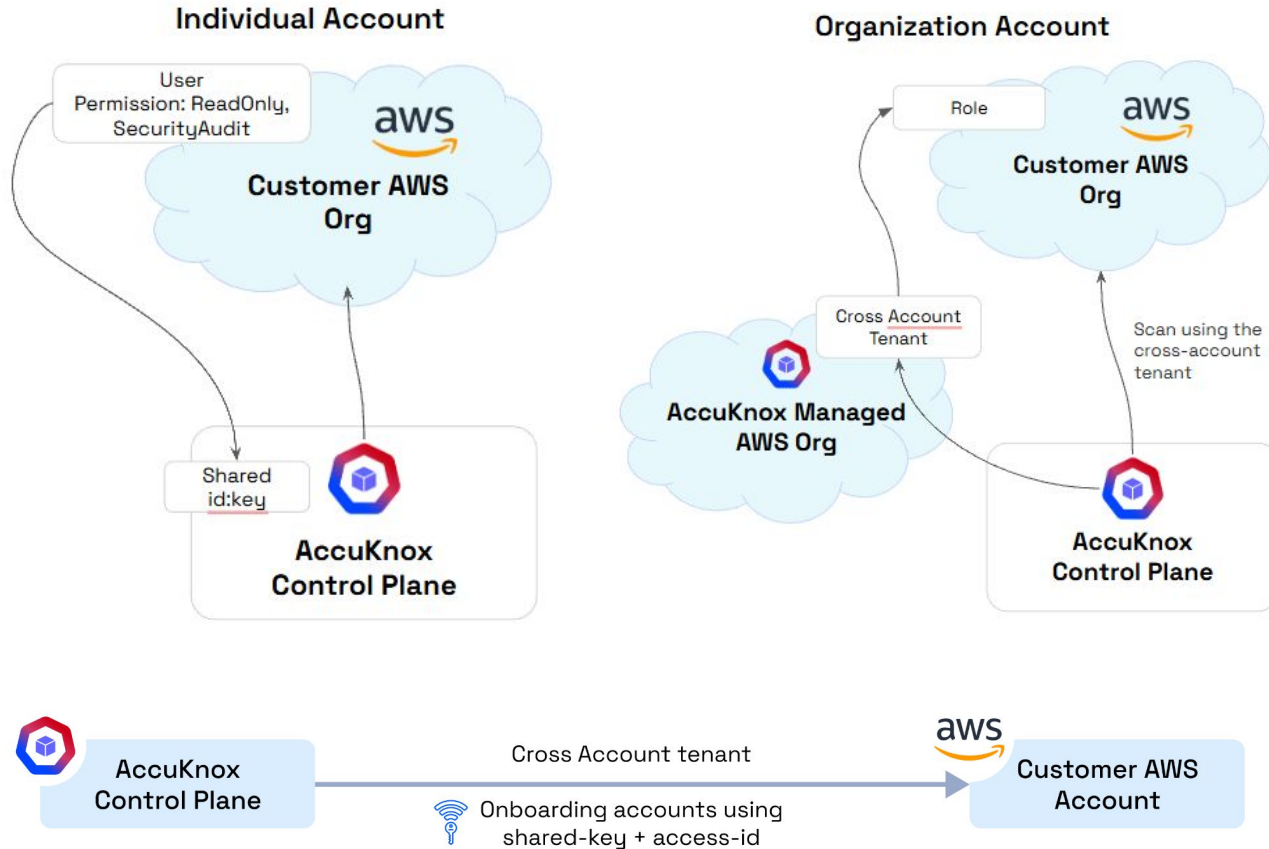
Alerting

Slack workspace + channel name
Teams webhook URL (optional)

SIEM (Optional)

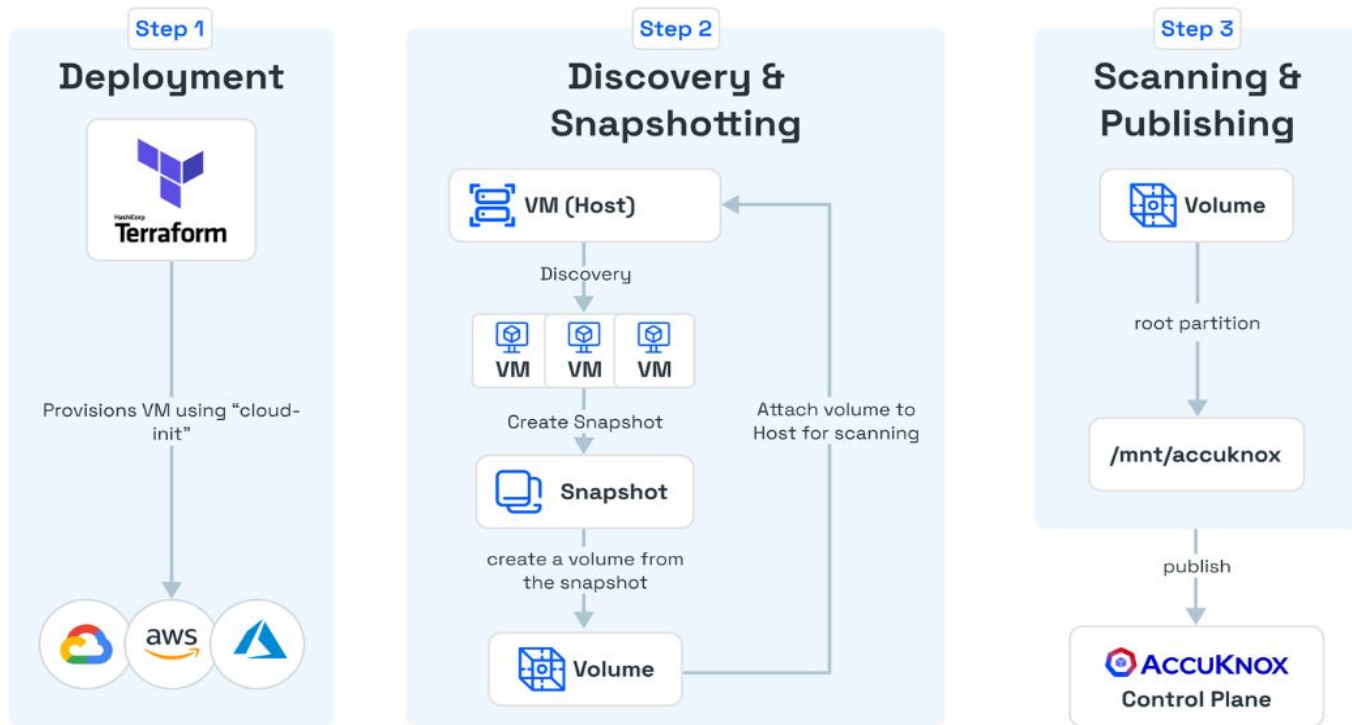
Splunk or ELK endpoint for log forwarding

CSPM Onboarding - AWS Standalone or Org Account

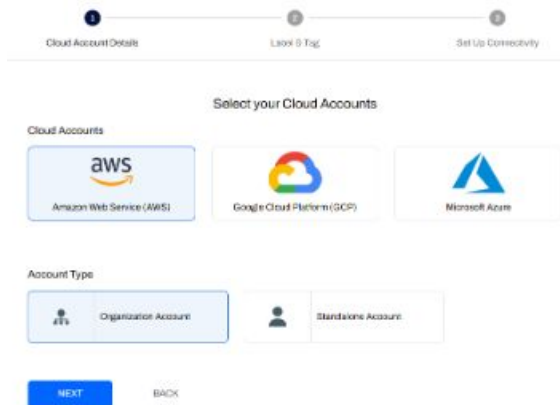


Agentless VM Scanning for Cloud Accounts

- [Agentless Cloud VM Scanning Help Docs - Getting Started Guide](#)
- [Azure Cloud VM Scan Help Docs \(Example\)](#)



AI Asset Onboarding Is Part Of Cloud Onboarding



Access Key ID* Show steps

Enter the Access Key ID*

Secret Access Key*

Enter the Secret Access Key

Region*

Select Regions

Scan Asset Type*

☐ General Cloud Assets

☒ General Cloud and AIML Assets

Check this radio button to detect and onboard all your AI/ML Assets from the Cloud Account

Back Cancel Connect

Useful Links:

1. [Permissions Required to Onboard AWS Accounts](#)
2. [Steps to Onboard AI/ML Cloud Asset](#) (Part of Cloud Onboarding)
3. [Enable Additional Permissions \(for AI Assets\)](#)

Use Cases — CSPM & Continuous Compliance



Global Asset Inventory

- Auto-discover and categorize 50+ AWS asset types across all regions and accounts
- Ghost resource detection: orphaned EBS volumes, unattached EIPs, stale IAM users
- Egress/Ingress mapping: flag ports open to 0.0.0.0/0 (SSH/RDP/HTTP/HTTPS)
- Asset grouping by tag, account, region, and compliance scope for granular reporting

Toxic Combination Analysis

- Correlates isolated findings into exploitable attack chains — not just raw alert counts
- Example: Public EC2 + Missing IMDSv2 + Overprivileged Instance Role = High-priority path
- Example: Unencrypted RDS + Public Subnet + Permissive SG = Data exfiltration risk
- Risk score based on exploitability AND blast radius — prioritizes what matters most

Drift Detection & IaC Alignment

- Detects "console drift" when infra diverges from approved Terraform / CloudFormation
- Tracks who made the change, when, and from which IP (CloudTrail correlation)
- Flags IaC templates with hardcoded credentials, open SGs, or missing encryption
- Export findings as annotated IaC diff for engineering team remediation

Compliance Framework Coverage



CIS Benchmarks v2.0

EC2, S3, IAM, RDS, VPC, EKS

200+
controls



NIST 800-53 Rev 5

Federal controls — audit-ready export

110+
controls



SOC2 Type II

Continuous evidence collection

64+
controls



HIPAA

PHI encryption, access, audit trail

54+
controls



PCI-DSS v4.0

Cardholder data env scoping

80+
controls



ISO 27001

ISMS control validation

114+
controls



AWS Well-Architected

Security pillar alignment

50+
controls

IAM Hardening

Root Account MFA

Detect root accounts with MFA disabled — flag as Critical immediately

Stale Access Keys

Flag access keys not rotated in > 90 days — includes unused keys

Over-Privileged Roles

Identify roles with *, Admin, or wildcard service permissions

Shadow Admins

Detect IAM users/roles that can escalate to admin via policy chaining

Unused Identities

Service accounts and IAM users with zero API calls in 30+ days

Cross-Account Trust

Flag overly permissive cross-account trust policies and external IDs

Secrets & Data Discovery

RDS Encryption

DB instances missing encryption at rest or in-transit (TLS disabled)

EBS Volumes

Unencrypted EBS volumes attached to running EC2 instances

Embedded Secrets

Scan Lambda env vars, ECS task defs, SSM Parameter Store for plaintext keys

AI / Bedrock Governance

Bedrock Discovery

Identify active Bedrock models, inference endpoints, and agent configs

IAM Scope

Detect over-permissive roles with bedrock:* or full InvokeModel access

Audit Logging

Validate CloudTrail logging for Bedrock API calls is enabled

Encryption

Confirm model input/output and artifact encryption via CMK / BYOK

Data Residency

Flag cross-region inference calls outside approved data residency zones

Public Exposure

S3 Encryption

Buckets missing SSE-S3 / SSE-KMS — flag unencrypted or public objects

Public DB Access

RDS instances with publicly_accessible=true or SGs open to 0.0.0.0/0

Endpoint Exposure

Flag Bedrock APIs accessible without VPC endpoint or PrivateLink

Missing Logging

S3 access logging, RDS audit logs, Lambda execution logs disabled

POC Success Criteria Matrix

Category	Use Case	Success Criteria	Status
Visibility	Asset Discovery	100% of AWS assets discovered across all regions and accounts	☐
CSPM	Misconfiguration Scan	Top-20 critical misconfigs identified and risk-ranked on Day 3	☐
CSPM	Toxic Combinations	At least 1 chained attack path identified per account	☐
Compliance	CIS + NIST 800-53	Accurate pass/fail posture report generated for both frameworks	☐
Compliance	SOC2 / HIPAA	SOC2 and HIPAA compliance scores generated with control mapping	☐
CDR	S3 Auto-Remediation	Exposed S3 bucket reverted to private within 60 seconds of event	☐
CDR	EC2 Public IP Removal	Public IP detached from EC2 within 90 seconds of policy violation	☐
CDR	Geo-Fencing Alert	Critical alert fired within 30 seconds of access from denied region	☐
IAM	Identity Hardening	MFA-disabled root accounts, stale keys, over-privileged roles found	☐
AI / Bedrock	AI Asset Audit	Bedrock models discovered, logging validated, IAM scope reviewed	☐
Integration	Jira Ticketing	Auto-formatted Jira ticket created per critical finding	☐
Integration	Slack Alerts	Real-time Slack alert fires on CDR event with asset context	☐

POC Execution Plan — 2-Week Sprint



Activity / Deliverable	WEEK 1 — Onboarding & Discovery							WEEK 2 — CSPM Findings & Reporting						
	D1	D2	D3	D4	D5	D6	D7	D8	D9	D10	D11	D12	D13	D14
Prerequisites finalization & scoping	•	•												
AccuKnox Control Plane connectivity	•	•												
Cloud Account Onbaording	•	•												
Jira & Slack integration setup		•	•											
Full asset inventory scan			•	•										
Baseline compliance scores (CIS, NIST, SOC2, HIPAA)			•	•	•									
Toxic combination analysis walkthrough				•	•									
IAM & data security findings review					•									
Enable CDR write permissions for testing						•	•							
CDR simulation: S3 public exposure							•	•						
CDR simulation: EC2 public IP + Geo-Fencing								•	•					
Bedrock / AI asset audit									•	•				
Executive report generation										•	•	•		

Weekly Triaging Sessions with AccuKnox to Fix Cloud Security Posture + Understand Top Cloud Risks



+



Weekly Triaging Working Session to Fix Cloud Security Posture

[See Sample PoC Executive Summary Report](#)

What You Get Weekly?

1

Which Findings to Prioritize

2

What are the Threat Vectors

3

Which Issues Need Attention

4

Top Cloud Misconfigurations

5

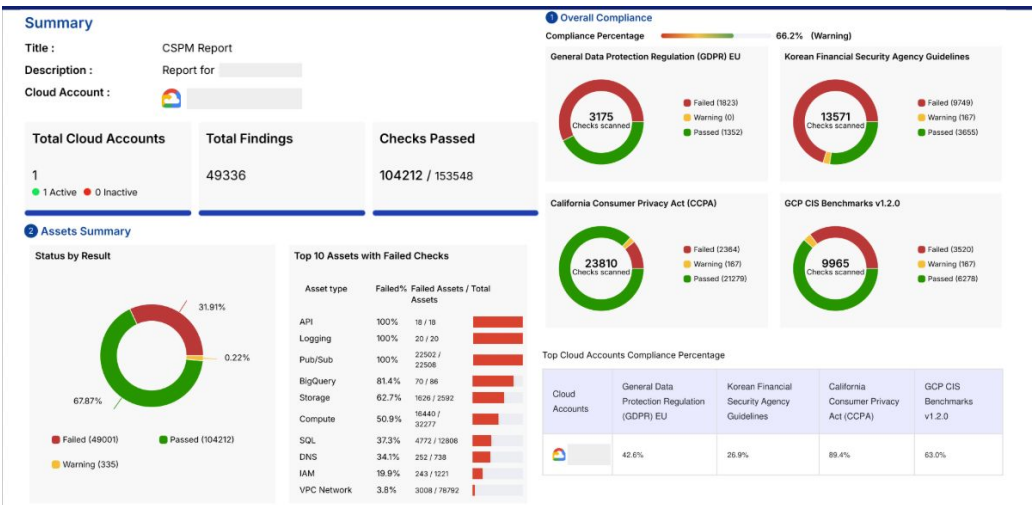
Compliance Related Alerts

6

Cloud Account Status & Findings

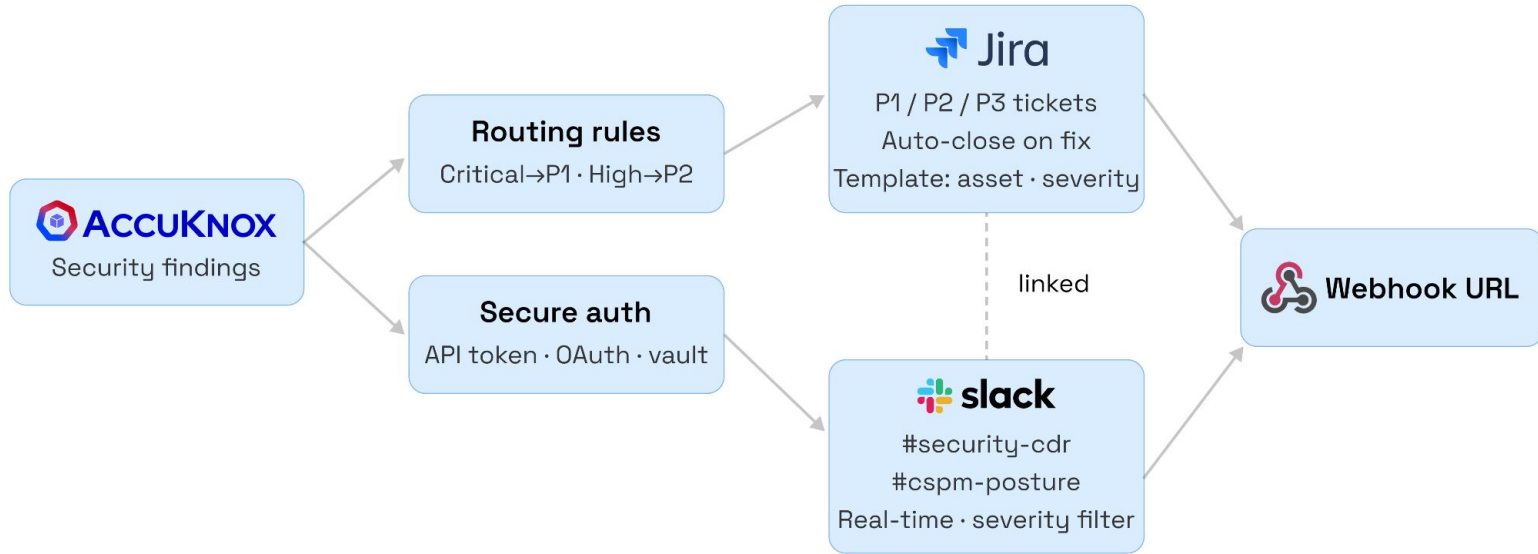
7

Cloud Inventory



Get Your Compliance Summary and Cloud Security Posture Report Triaging Done with AccuKnox in a guided fashion.

Integrations & Channel Alert Configuration



Additional Integration Options (See [Full Integrations List](#))

ServiceNow

ITSM ticketing — SNOW table API, dynamic incident template

PagerDuty

On-call escalation for Critical CDR events — severity routing

Email

SMTP-based daily digest and individual finding alerts

Webhooks (Generic)

Custom endpoint for CI/CD pipeline or internal tooling

CSPM Reports, Integrations & Notifications



[CSPM PDF Report: help.accuknox.com/resources/assets/CSPM_Report.pdf](https://help.accuknox.com/resources/assets/CSPM_Report.pdf)

Cloud Findings

Feb 12, 2025 12:00:00
to Mar 12, 2025 12:00:00

Cloud Accounts

Data is based on time of report generation

21 Accounts ● 18 Active ● 3 Inactive



8 Accounts
● 7 Active
● 1 Inactive



9 Accounts
● 7 Active
● 2 Inactive



4 Accounts
● 4 Active
● 0 Inactive

Manage multiple cloud accounts effortlessly with real-time visibility. Quickly identify active and inactive accounts for better control and governance.

Total Asset Count by Cloud Provider



View total cloud assets at a glance with clear insight into impacted assets. Easily track assets affected by security findings for faster risk mitigation.

Total Assets



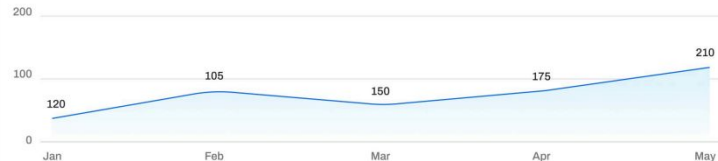
Monitor total assets growth or reduction over time with historical trends. Gain insights into infrastructure changes and optimize resource planning.

Assets by Category

Assets	Count
Containers	18.5k
AWS Identity	1.5k
Serverless	1,000
Database	1,100
Storage	150
+ Others	120

Get a clear breakdown of assets by category for better resource visibility. Quickly identify distribution across compute, storage, network, and more.

New Cloud Findings Trend



Stay on top of newly discovered findings for timely risk mitigation. Quickly identify emerging security issues as they surface across your environment.

Findings by Insights

Insight	Severity	Findings
Public Buckets Access	Critical	3,239
Publicly Available Database	Critical	233
Access Keys Older than 180 Days	High	122
Misconfigured Identity and Access Management (IAM) Policies	Medium	9
All/Custom Ports Publicly Available	Low	2

View security findings categorized by specific insights for deeper analysis. Understand vulnerabilities, misconfigurations, and compliance gaps through detailed insights.

Findings by Tags

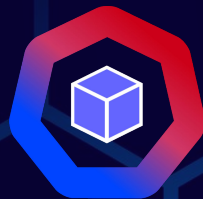
300 Potential Exposure	102 Authentication & Authorization	65 Privileged Assets	300 Outdated Components	102 Encryption Issues	65 Public Exposure
20 Availability Issues	1 Logging & Monitoring	90 Maintainability Issues	90 Unused Assets		

Check Out the Full CSPM Playbook



[VIEW PLAYBOOK](#)





ACCUKNOX

SEE US IN ACTION

support@accuknox.com

Certified by

